

CORS & Preflight Requests – Concept + Practical

Investigation

Part 1 – Concept Understanding

Objective

1. What is CORS and why it exists

Cors is the Cross Origin Resource Sharing having the browser to manage the how origin of frontend at one address to fetch data from server at different address.

It exists with user and by default the browser was having the same origin policy it will block the websites.

2. What is an Origin

Origin the fundamental identity of application . It has a 3 components of combination From url. Scheme, host and port

Scheme: the protocol used to access the resource like having (http:// or https://)

Host: host is the domain name like (example.com).

Port : the network communication endpoint

If u taking the 2 url to consider as same origin all of three elements are match correctly.

If even a single element mismatch the browser will clarify as a cross origin.

Cross origin- if the scheme is different like one having http and another having https it will allow to access.

3.What is a Cross-Origin Request

A cross origin is a fetching the data from frontend and backend application. Like one website tries to fetch the data from different website.

4. Simple Requests vs Preflighted Requests

Simple request is a safe method for browser to send the request immediately without needing the permission.

Preflighted request is a complex standard is while giving the request to the browser it will pause and send to the server it will verify the security rules if the request is matches it will allow to access and if not matches it will block.

5.What is a Preflight OPTIONS Request

It is the actual request send to the server by using the option . Through the option we sends the information to server . if the request satisfies to the server it will allow to access or it will not allow.

6.What Triggers a Preflight

Using the preflight trigger

Using a Non-Simple HTTP Method(put, delete, patch)

Sending a Non-Simple Content-Type application/json

Including Custom Headers like authorisation or api key

7. Key CORS Response Headers

This header specifies which frontend websites are allowed to access the server's data.

Specific Domain: Access-Control-Allow-Origin: https://my-app.com (Only this exact site can read the data).

Access-Control-Allow-Methods

Returned during a preflight request, this header lists the allowed HTTP actions.

Example: Access-Control-Allow-Methods: GET, POST, PUT, DELETE

Access-Control-Allow-Headers

This header explicitly lists which custom HTTP headers the frontend is permitted to send.

Example: Access-Control-Allow-Headers: Content-Type, Authorization

Access-Control-Allow-Credentials

This header tells the browser whether it is allowed to expose the server's response when the request includes sensitive data like cookies, TLS client certificates, or HTTP authentication.

Example: Access-Control-Allow-Credentials: true

8. Why it works in Postman or curl but not in the browser

Postman or curl will run locally but it is api testing it do not have the user session by the browser will have this and prevent with the malicious website.

Part 2 – Talk to Senior Developer

Problem

They worked as a project in that project the backend and configure the response header of the server as access control access origin as * that is the problem

Solution: instead of keep the access control allow origin * for that they listed the specific origin and then worked. Modify the header property and make it request from other origins.

My takeaway : I need to list the specific domain origin which is to access the site and no using the wildcard.while i am working in a site i will make sure to use same origin and configure the cors properly.